CHƯƠNG 1

TỔNG QUAN AN TOÀN THÔNG TIN

CIA TRIAD • ZERO TRUST • TẤN CÔNG • ISO 27001 • GDPR



08:00 sáng — cổng sinh viên ngừng hoạt động

Ba dấu hiệu xuất hiện cùng lúc

Không truy cập được

Hàng nghìn yêu cầu bất thường làm nghẽn dịch vụ.

Tài khoản bị chiếm

Một email “nâng cấp mật khẩu” đã đánh lừa người dùng.

Dữ liệu bị thay đổi

Một số điểm số không còn khớp với bản gốc.

Câu hỏi mở: đây là một sự cố hay ba sự cố khác nhau?

Sau chương này, sinh viên có thể…

Mục tiêu học tập

- Giải thích và vận dụng bộ ba CIA để phân tích sự cố
- Mô tả tư duy Zero Trust và quyết định truy cập theo ngữ cảnh
- Phân biệt DDoS, APT và Social Engineering
- Trình bày vai trò của ISO/IEC 27001 và GDPR
- Đề xuất biện pháp bảo vệ phù hợp cho một tình huống thực tế

Hiểu → phân tích → đề xuất

Bản đồ học tập của Chương 1

01

Mục tiêu bảo mật
CIA triad

02

Mô hình truy cập
Zero Trust

03

Mối đe dọa
DDoS • APT • SE

04

Quản trị & pháp lý
ISO 27001 • GDPR

Khởi động: hệ thống nào “an toàn” hơn?

Chọn phương án tốt nhất

A. Không ai bên ngoài truy cập được

B. Dữ liệu không bị sửa

C. Dịch vụ luôn hoạt động

D. Cần đồng thời bảo vệ bí mật, toàn vẹn và sẵn sàng

Đáp án: D — an toàn thông tin là bài toán cân bằng nhiều mục tiêu.

PHẦN 1

CIA TRIAD & ZERO TRUST

Từ mục tiêu cần bảo vệ đến cách ra quyết định truy cập



ATTT bảo vệ thông tin trong suốt vòng đời

Không chỉ là “chống hacker”

An toàn thông tin bảo vệ thông tin và hệ thống trước truy cập, sử dụng, tiết lộ, gián đoạn, sửa đổi hoặc phá hủy trái phép.

Con người

Quy trình

Công nghệ

Bốn khái niệm tạo nên rủi ro

Tài sản

Điều có giá trị cần bảo vệ: **dữ liệu sinh viên, website nhà trường, uy tín của trường.**

Mối đe dọa

Tác nhân hoặc sự kiện có thể gây hại: **tin tặc đánh cắp dữ liệu, mã độc mã hóa tệp, cháy phòng máy.**

Lỗ hổng

Điểm yếu có thể bị khai thác: **mật khẩu dễ đoán, phần mềm chưa vá lỗi, phân quyền truy cập quá rộng.**

Rủi ro

Khả năng xảy ra thiệt hại và mức độ ảnh hưởng: **dữ liệu sinh viên có thể bị đánh cắp do tài khoản quản trị sử dụng mật khẩu yếu, dẫn đến lộ thông tin và giảm uy tín nhà trường.**

Ví dụ: dữ liệu điểm + kẻ tấn công + mật khẩu yếu → nguy cơ sửa điểm.

CIA là ba mục tiêu cốt lõi của bảo mật

C

Confidentiality

Chỉ chủ thể được phép mới xem được thông tin.

I

Integrity

Thông tin chính xác, đầy đủ và không bị sửa trái phép.

A

Availability

Thông tin và dịch vụ sẵn sàng khi người dùng hợp lệ cần.

Confidentiality — ngăn tiết lộ trái phép

C

Câu hỏi trọng tâm: Ai được phép biết thông tin này?

- Xác định dữ liệu nhạy cảm
- Giới hạn người được truy cập
- Bảo vệ dữ liệu khi lưu trữ và truyền tải

Mất bí mật có nhiều hình thức

Tình huống

- Lộ danh sách sinh viên
- Đọc trộm email
- Sao chép mã nguồn
- Nghe lén lưu lượng

Hậu quả

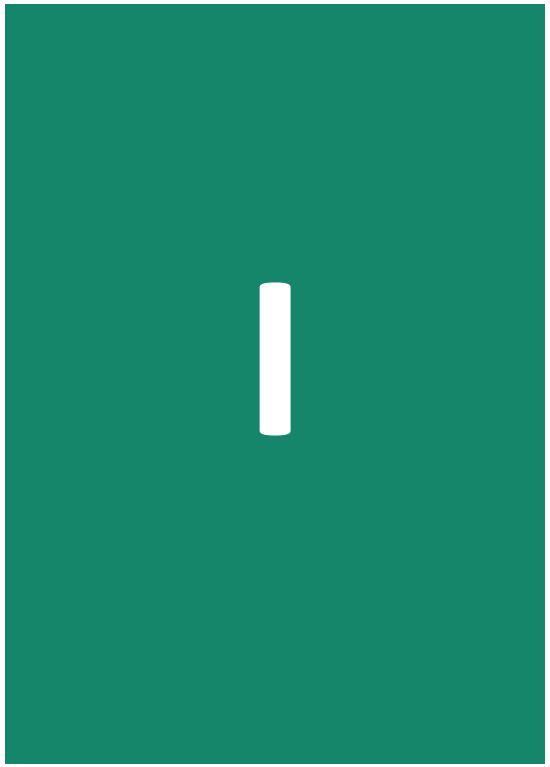
- Xâm phạm riêng tư
- Mất lợi thế cạnh tranh
- Tổn thất tài chính
- Rủi ro pháp lý và uy tín

Kiểm soát bí mật theo nhiều lớp

01	**Dữ liệu**	Mã hóa, phân loại, che dữ liệu
02	**Truy cập**	MFA, phân quyền, đặc quyền tối thiểu
03	**Mạng**	TLS, VPN, phân đoạn mạng
04	**Con người**	Đào tạo, cam kết, quy trình chia sẻ

Không có một biện pháp đơn lẻ nào bảo vệ được mọi đường rò rỉ.

Integrity — bảo vệ tính đúng đắn của thông tin



Câu hỏi trọng tâm: Dữ liệu có còn đúng và đáng tin cậy không?

- Ngăn sửa đổi trái phép
- Phát hiện thay đổi
- Khôi phục về trạng thái tin cậy

Toàn vẹn có thể mất do tấn công hoặc sai sót

Cố ý

- Sửa điểm hoặc số dư
- Chèn mã độc vào phần mềm
- Thay đổi log để che dấu

Vô ý

- Nhập sai dữ liệu
- Lỗi phần mềm
- Đồng bộ ghi đè bản mới
- Cấu hình nhầm

Kiểm soát toàn vẹn cần phòng ngừa và phát hiện

01	**Xác thực**	Chữ ký số, MAC, checksum
02	**Thay đổi**	Version control, phê duyệt hai bước
03	**Nhật ký**	Audit log chống sửa, giám sát
04	**Phục hồi**	Sao lưu, kiểm thử khôi phục

Checksum phát hiện thay đổi; chữ ký số còn xác minh nguồn gốc.

Availability — dịch vụ sẵn sàng đúng lúc

A

Người dùng hợp lệ có truy cập được khi cần?

- Giảm điểm lỗi đơn
- Duy trì năng lực xử lý
- Khôi phục nhanh sau sự cố

Sẵn sàng bị đe dọa bởi cả kỹ thuật và vận hành

Sự kiện

- DDoS
- Hỏng phần cứng
- Mất điện hoặc đường truyền
- Ransomware
- Lỗi cập nhật

Chỉ số cần theo dõi

- Uptime
- Thời gian phản hồi
- RTO — thời gian phục hồi
- RPO — mức mất dữ liệu chấp nhận

Thiết kế sẵn sàng từ trước khi sự cố xảy ra

01	**Dự phòng**	Cluster, nhiều đường truyền, nguồn dự phòng
02	**Khả năng chịu tải**	Auto scaling, cache, CDN
03	**Phục hồi**	Backup, DR site, runbook
04	**Giám sát**	Alert, log, kiểm thử định kỳ

Dự phòng chưa đủ nếu không kiểm thử chuyển đổi và khôi phục.

Ba mục tiêu CIA thường tạo ra đánh đổi

Bí mật cao

Kiểm soát truy cập chặt hơn

Toàn vẹn cao

Nhiều bước xác minh hơn

Sẵn sàng cao

Nhiều bản sao và điểm truy cập hơn

Thiết kế theo rủi ro

Mục tiêu không phải tối đa hóa từng trục, mà là đạt mức phù hợp với bối cảnh.

Hoạt động: phân loại tác động theo CIA

Theo nhóm, gán C, I, A cho từng tình huống

Email bảng lương gửi nhầm người —
File cấu hình bị sửa trái phép —
Website đăng ký môn bị nghẽn —
Ransomware mã hóa cơ sở dữ liệu —
Tài khoản quản trị bị lộ —

Giải thích vì sao một sự cố có thể tác động nhiều mục tiêu.

Hoạt động: phân loại tác động theo CIA

Theo nhóm, gán C, I, A cho từng tình huống

Email bảng lương gửi nhầm người — C
File cấu hình bị sửa trái phép — I
Website đăng ký môn bị nghẽn — A
Ransomware mã hóa cơ sở dữ liệu — I + A
Tài khoản quản trị bị lộ — C + I + A

Giải thích vì sao một sự cố có thể tác động nhiều mục tiêu.

Mini case: cổng thông tin sinh viên

Một sinh viên nhận được đường link giả, nhập mật khẩu; sau đó điểm bị sửa và hệ thống bị khóa.

1. Tài sản quan trọng là gì?
2. CIA bị ảnh hưởng theo thứ tự nào?
3. Biện pháp nào có thể cắt chuỗi sự cố sớm nhất?

Gợi ý: MFA + phát hiện đăng nhập bất thường + log chống sửa + bản sao lưu.

Kiểm tra nhanh: CIA

Biện pháp nào chủ yếu bảo vệ Integrity?

A. CDN

B. Chữ ký số

C. Mã hóa ổ đĩa

D. Load balancing

Đáp án: B. Chữ ký số giúp phát hiện thay đổi và xác minh nguồn.

Zero Trust loại bỏ niềm tin mặc định

Không tin chỉ vì vị trí mạng

Mọi yêu cầu truy cập phải được xác thực, ủy quyền và đánh giá dựa trên chủ thể, thiết bị, tài nguyên và ngữ cảnh.

Verify explicitly

Least privilege

Assume breach

Vì sao mô hình “lâu đài và hào nước” không đủ?

Mô hình chu vi

- Tin mạng nội bộ
- Kiểm tra chủ yếu ở cổng vào
- Quyền truy cập thường rộng
- Khó kiểm soát di chuyển ngang

Zero Trust

- Không tin mặc định
- Đánh giá từng phiên truy cập
- Quyền nhỏ và có thời hạn
- Thực thi gần tài nguyên

Bảy nguyên lý Zero Trust theo NIST

1 Mọi nguồn dữ liệu và dịch vụ là tài nguyên

2 Mọi giao tiếp đều được bảo vệ

3 Truy cập theo từng phiên và đặc quyền tối thiểu

4 Chính sách dựa trên thuộc tính và ngữ cảnh

5 Theo dõi trạng thái tài sản liên tục

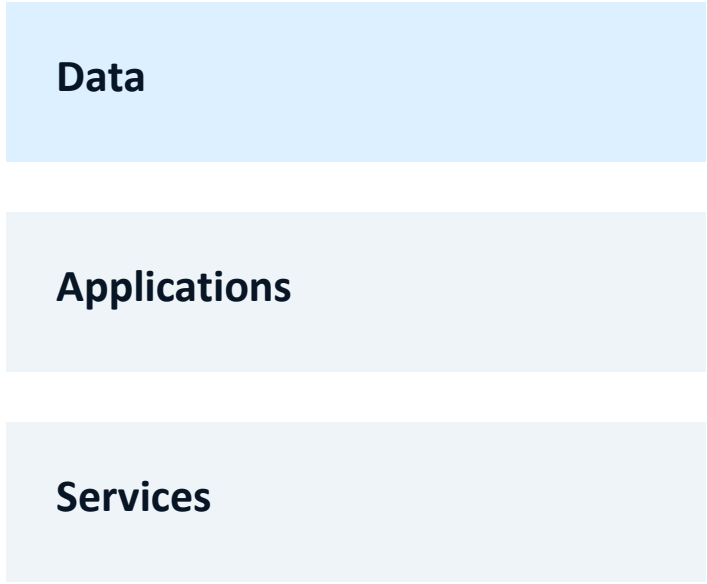
6 Xác thực và ủy quyền động, nghiêm ngặt

7 Thu thập dữ liệu để cải thiện chính sách

Zero Trust bảo vệ tài nguyên, không bảo vệ “vùng”

Resource-centric security

Đối tượng cần bảo vệ là dữ liệu, ứng dụng, dịch vụ và quy trình. Vị trí IP chỉ là một tín hiệu, không phải bằng chứng đủ để tin cậy.



Quyết định truy cập được tách khỏi thực thi

Policy Engine

Quyết định cho phép/ từ chối

Policy Administrator

Thiết lập hoặc dừng phiên

Policy Enforcement Point

Thực thi trước tài nguyên

Luồng điều khiển ra quyết định; luồng dữ liệu chỉ mở khi chính sách cho phép.

Một yêu cầu truy cập được đánh giá bằng nhiều tín hiệu

Identity

Ai đang yêu cầu?

Device

Thiết bị có an toàn?

Resource

Tài nguyên nhạy cảm mức nào?

Context

Vị trí, thời gian, hành vi?

Threat

Có chỉ báo rủi ro mới?

Decision = Policy(identity + device + resource + context + threat)

Triển khai Zero Trust theo lộ trình tăng dần

01

Lập danh mục tài sản & luồng dữ liệu

02

Củng cố identity + MFA

03

Thu hẹp quyền & phân đoạn

04

Đo lường, tự động điều chỉnh chính sách

Không cần thay toàn bộ hạ tầng trong một lần.

Ứng dụng Zero Trust cho hệ thống LMS

Giảng viên đăng nhập từ laptop cá nhân ở nước ngoài để tải toàn bộ danh sách điểm.

1. Tín hiệu nào làm tăng rủi ro?
2. Có nên chặn hoàn toàn không?
3. Kiểm soát thích ứng nào phù hợp?

Gợi ý: MFA mạnh, kiểm tra thiết bị, giới hạn tải, phê duyệt bổ sung, giám sát phiên.

Checkpoint: Zero Trust

Phát biểu nào đúng nhất?

A. Không bao giờ cho phép truy cập

B. Chỉ tin thiết bị do công ty cấp

C. Không cấp niềm tin ngầm; đánh giá từng yêu cầu

D. Chỉ cần triển khai MFA

Đáp án: C. MFA quan trọng nhưng chỉ là một thành phần.

PHẦN 2

CÁC LOẠI TẤN CÔNG

DDoS đánh vào dịch vụ • APT bám trụ dài hạn • Social Engineering đánh vào con người



Ba kiểu tấn công khác nhau về mục tiêu và nhịp độ

Đặc điểm	DDoS	APT	Social Engineering
Mục tiêu chính	Làm gián đoạn	Bám trụ / đánh cắp	Thao túng con người
Thời gian	Ngắn–trung hạn	Dài hạn	Theo từng chiến dịch
Dấu hiệu	Lưu lượng tăng vọt	Yếu và phân tán	Thông điệp bất thường
CIA thường bị tác động	A	C + I	C / I / A

DDoS làm người dùng hợp lệ không thể truy cập

Distributed Denial of Service

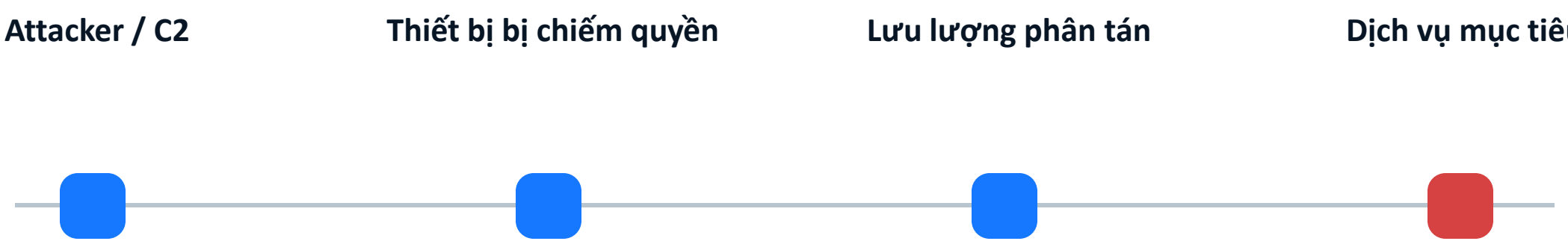
Nhiều nguồn đồng thời gửi lưu lượng hoặc yêu cầu để làm cạn băng thông, kết nối hay tài nguyên ứng dụng của mục tiêu.

Nhiều nguồn

Tài nguyên cạn

Dịch vụ gián đoạn

Botnet khuếch đại sức tấn công



Nguồn phân tán khiến chặn theo một địa chỉ IP không hiệu quả.

DDoS thường xuất hiện ở ba lớp

01

Volumetric

Làm đầy băng thông bằng lưu lượng lớn.

02

Protocol

Khai thác trạng thái hoặc giới hạn giao thức.

03

Application

Gửi yêu cầu tốn tài nguyên ở lớp ứng dụng.

Reflection và amplification che nguồn, tăng lưu lượng

1

Giả mạo IP nạn nhân

2

Gửi truy vấn nhỏ tới máy phản xạ

3

Nhận phản hồi lớn hơn

4

Phản hồi dồn về nạn nhân

Giảm thiểu: chống spoofing, cấu hình dịch vụ đúng, lọc và dịch vụ scrubbing.

Phân biệt DDoS và lượng truy cập hợp lệ

DDoS

- Mẫu truy cập lặp bất thường
- Phân bố địa lý đáng ngờ
- Tỷ lệ lỗi kết nối cao
- Không gắn với sự kiện kinh doanh

Flash crowd

- Người dùng thực
- Hành vi điều hướng đa dạng
- Tăng theo chiến dịch/sự kiện
- Có khả năng chuyển đổi

Phòng thủ DDoS cần nhiều tầng

01	**Edge**	Anycast, CDN, scrubbing
02	**Network**	ACL, rate limit, upstream filtering
03	**Application**	WAF, cache, bot management
04	**Operations**	Baseline, alert, playbook, diễn tập

Phối hợp sớm với ISP/CDN vì lưu lượng có thể làm nghẽn trước khi tới máy chủ.

Ứng phó DDoS theo playbook



Ghi lại thời điểm, chỉ số, quyết định và bằng chứng để phục vụ hậu kiểm.

Bài tập nhóm: website tuyển sinh bị nghẽn

Thiết kế phản ứng trong 10 phút

Dấu hiệu cần kiểm tra	Băng thông, RPS, CPU, lỗi 5xx, nguồn truy cập
Đối tác cần liên hệ	ISP, CDN/WAF, đội ứng dụng, truyền thông
Quyết định ưu tiên	Duy trì trang thiết yếu; giới hạn chức năng nặng
Bằng chứng cần giữ	Flow logs, WAF logs, timeline, cấu hình thay đổi

Nhóm trình bày một hành động “trước – trong – sau” sự cố.

APT là đối thủ có năng lực và kiên trì

Advanced Persistent Threat

Đối thủ dùng nhiều vector, thích ứng với phòng thủ và duy trì hiện diện trong thời gian dài để đạt mục tiêu chiến lược.

Advanced

Persistent

Goal-driven

Ba từ trong APT mô tả cách đối thủ hoạt động

A

Advanced

Chuyên môn, tài nguyên và nhiều kỹ thuật.

P

Persistent

Theo đuổi lâu dài, quay lại và thích ứng.

T

Threat

Đối thủ có mục tiêu, ý định và năng lực.

APT tiến triển qua nhiều giai đoạn



Xâm nhập

Tạo chỗ đứng

Nâng quyền & di chuyển

Thu thập / đánh cắp

Mô hình thực tế có thể lặp lại; phát hiện sớm giúp giảm phạm vi ảnh hưởng.

APT kết hợp kỹ thuật thay vì phụ thuộc một lỗ hổng

Đường vào

- Spear phishing
- Khai thác dịch vụ công khai
- Chuỗi cung ứng
- Tài khoản hợp lệ bị chiếm

Bám trụ & hành động

- Persistence
- Credential dumping
- Lateral movement
- Command and control
- Exfiltration

Dấu hiệu APT thường yếu nhưng liên kết được

Identity	Endpoint	Network	Data	Behavior
Đăng nhập lạ, impossible travel	Tiến trình và persistence bất thường	Beaconing, DNS lạ, C2	Nén, staging, truyền dữ liệu	Chuỗi hành động khác baseline

Giá trị nằm ở tương quan nhiều tín hiệu theo thời gian.

Chống APT là cuộc chơi phát hiện và hạn chế thiệt hại

01	**Ngăn xâm nhập**	MFA, vá lỗi, email security
02	**Giảm di chuyển**	Segmentation, PAM, least privilege
03	**Phát hiện**	EDR, SIEM, threat hunting
04	**Ứng phó**	Cô lập, điều tra, phục hồi, lessons learned

Giả định có vi phạm giúp thiết kế khả năng phát hiện và khống chế.

Threat hunting: ghép các mảnh tín hiệu

Sắp xếp chuỗi sự kiện thành giả thuyết APT

09:12	—	Đăng nhập VPN từ vị trí lạ
09:18	—	PowerShell tạo scheduled task
10:04	—	Truy cập nhiều máy chủ nội bộ
11:31	—	Nén 4 GB dữ liệu
11:45	—	DNS beacon mỗi 60 giây

Chọn điểm nên cô lập đầu tiên và nêu bằng chứng cần thu thập.

Social Engineering khai thác niềm tin và cảm xúc

Con người trở thành “giao diện tấn công”

Kẻ tấn công dùng lừa dối và thuyết phục để khiến nạn nhân tiết lộ thông tin hoặc thực hiện hành động có lợi cho chúng.

Tin tưởng

Khẩn cấp

Tò mò

Kẻ tấn công thường kích hoạt ba phản xạ

!

Urgency

“Thực hiện ngay nếu không sẽ bị khóa.”

★

Authority

“Yêu cầu từ hiệu trưởng / giám đốc.”

?

Curiosity

“Xem danh sách lương mới nhất.”

Social Engineering không chỉ là phishing

Phishing

Thông điệp đại trà qua email/web.

Spear phishing

Nội dung cá nhân hóa cho mục tiêu.

Vishing / Smishing

Lừa qua điện thoại hoặc SMS.

Pretexting / Baiting

Dựng kịch bản hoặc dùng mồi nhử.

Kênh khác nhau, nguyên tắc thao túng tương tự.

Giải phẫu một email lừa đảo

1	**Người gửi**	Tên hiển thị giống thật; domain lệch một ký tự
2	**Thông điệp**	Tạo khẩn cấp, sợ hãi hoặc lợi ích bất ngờ
3	**Liên kết/tệp**	Đích thật khác nội dung hiển thị
4	**Yêu cầu**	Đăng nhập, chuyển tiền, cung cấp OTP

Thói quen: dừng lại → kiểm tra → xác minh qua kênh độc lập.

Giảm rủi ro cần cả công nghệ lẫn hành vi

01	**Email & web**	Filtering, sandbox, DMARC
02	**Identity**	MFA chống phishing, conditional access
03	**Quy trình**	Xác minh giao dịch qua kênh thứ hai
04	**Con người**	Đào tạo theo tình huống, nút report

Đừng biến người dùng thành “lớp phòng thủ cuối cùng” mà không có hỗ trợ kỹ thuật.

Nếu đã nhấp link: phản ứng nhanh hơn che giấu

1. **Ngắt tương tác, không nhập thêm**
2. **Báo cáo ngay cho bộ phận phụ trách**
3. **Đổi mật khẩu, thu hồi phiên, kiểm tra MFA**
4. **Quét thiết bị và theo dõi tài khoản**

Không đổ lỗi; văn hóa báo cáo sớm làm giảm thiệt hại.

Đóng vai: cuộc gọi “hỗ trợ kỹ thuật”

Người gọi biết tên, khoa và mã nhân viên; yêu cầu đọc mã OTP để “khôi phục email”.

1. Dấu hiệu thao túng nào xuất hiện?
2. Bạn sẽ nói gì để từ chối lịch sự?
3. Kênh nào dùng để xác minh?

Câu trả lời mẫu: Tôi không cung cấp OTP. Tôi sẽ gọi lại số hỗ trợ chính thức.

So sánh DDoS, APT và Social Engineering

Tiêu chí	DDoS	APT	Social Engineering
Đối tượng bị khai thác	Hạ tầng/dịch vụ	Toàn hệ thống	Con người/quy trình
Mục tiêu thường gặp	Gián đoạn	Bám trụ, đánh cắp	Lấy quyền hoặc thông tin
Tốc độ	Nhanh, dễ thấy	Chậm, kín đáo	Nhanh hoặc nhiều bước
Phòng thủ nổi bật	Năng lực + lọc	Telemetry + hunting	Xác minh + kiểm soát

Checkpoint: nhận diện kiểu tấn công

Kịch bản nào gần APT nhất?

A. 50.000 IP gửi UDP trong 5 phút

B. Email giả mạo yêu cầu nhập OTP

C. Đối thủ bám trụ nhiều tháng, di chuyển ngang và đánh cắp dữ liệu

D. Máy chủ hỏng ổ đĩa

Đáp án: C. Dấu hiệu cốt lõi là mục tiêu dài hạn, thích ứng và duy trì hiện diện.

PHẦN 3

ISO/IEC 27001 & GDPR

Từ kiểm soát kỹ thuật đến hệ thống quản lý và trách nhiệm pháp lý



Tiêu chuẩn và quy định trả lời hai câu hỏi khác nhau

ISO/IEC 27001

- Tiêu chuẩn về ISMS
- Tiếp cận dựa trên rủi ro
- Có thể được chứng nhận
- Áp dụng cho nhiều loại thông tin

GDPR

- Quy định pháp luật EU
- Bảo vệ dữ liệu cá nhân
- Tạo quyền cho cá nhân
- Đặt nghĩa vụ cho tổ chức

ISO/IEC 27001 xây dựng một hệ thống quản lý ATTT

ISMS — Information Security Management System

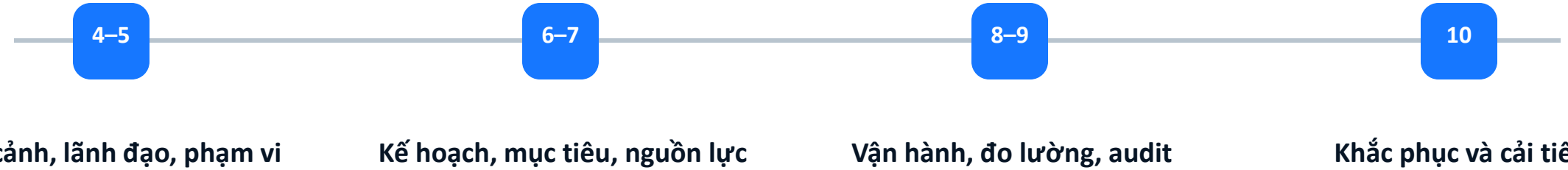
Tiêu chuẩn quy định yêu cầu để thiết lập, triển khai, duy trì và cải tiến liên tục hệ thống quản lý an toàn thông tin.

People

Policies

Technology

Các điều khoản 4–10 tạo thành vòng quản lý



ISMS là chu trình quản trị, không phải danh sách mua công nghệ.

Annex A 2022 nhóm kiểm soát thành bốn chủ đề

Organizational

Chính sách, vai trò, nhà cung cấp, sự cố.

People

Sàng lọc, nhận thức, trách nhiệm nhân sự.

Physical

Khu vực, thiết bị, môi trường vật lý.

Technological

Identity, mạng, mã hóa, logging, SDLC.

Tổ chức lựa chọn kiểm soát theo xử lý rủi ro và giải trình trong Statement of Applicability.

Quản lý rủi ro biến mục tiêu thành hành động

1. **Xác định tài sản, đe dọa, lỗ hổng**
2. **Đánh giá khả năng và tác động**
3. **Chọn xử lý: giảm, tránh, chuyển, chấp nhận**
4. **Theo dõi hiệu lực và rủi ro còn lại**

Chủ sở hữu rủi ro phải chấp nhận rủi ro còn lại một cách có căn cứ.

Lộ trình triển khai ISMS bắt đầu từ phạm vi rõ ràng

01

Xác định phạm vi & bên liên quan

02

Đánh giá rủi ro & chọn kiểm soát

03

Vận hành, đào tạo & thu bằng chứng

04

Audit nội bộ, review & cải tiến

Chứng nhận là kết quả của hệ thống vận hành, không phải đích duy nhất.

ISO 27001 không bảo đảm miễn nhiễm tấn công

Chứng minh được

- Có phạm vi ISMS xác định
- Có quy trình quản lý rủi ro
- Có kiểm soát và bằng chứng vận hành
- Có cơ chế cải tiến

Không tự động chứng minh

- Mọi hệ thống đều an toàn tuyệt đối
- Mọi rủi ro đã bằng 0
- Phạm vi ngoài chứng nhận cũng đạt chuẩn
- Sẽ không còn sự cố

GDPR bảo vệ dữ liệu cá nhân của con người

Personal data + processing + responsibility

GDPR áp dụng theo phạm vi hoạt động và đối tượng được nhắm tới; dữ liệu cá nhân được bảo vệ bất kể công nghệ xử lý.

Controller

Processor

Data subject

Bảy nguyên tắc GDPR định hướng toàn bộ vòng đời dữ liệu

1 Hợp pháp, công bằng và minh bạch

2 Giới hạn mục đích

3 Tối thiểu hóa dữ liệu

4 Giới hạn thời gian lưu trữ

5 Đảm bảo chính xác

6 Toàn vẹn và bí mật

7 Trách nhiệm giải trình

GDPR trao quyền cho cá nhân và đặt nghĩa vụ cho tổ chức

Quyền của cá nhân

- Được thông tin và truy cập
- Sửa dữ liệu
- Xóa hoặc hạn chế xử lý
- Di chuyển dữ liệu
- Phản đối và quyền liên quan quyết định tự động

Nghĩa vụ tổ chức

- Có cơ sở pháp lý
- Privacy by design/default
- Bảo mật phù hợp rủi ro
- Quản lý bên xử lý và chuyển dữ liệu
- Thông báo vi phạm theo điều kiện luật định

Tình huống tích hợp: nền tảng học tập bị xâm nhập

Tài khoản quản trị bị phishing; dữ liệu sinh viên bị tải xuống; website sau đó bị DDoS để che dấu hoạt động.

1. CIA bị tác động như thế nào?
2. Zero Trust đã có thể chặn ở điểm nào?
3. ISMS cần kích hoạt quy trình nào?
4. Dữ liệu cá nhân kéo theo nghĩa vụ GDPR nào?

Trả lời theo chuỗi: phát hiện → cô lập → bảo toàn bằng chứng → đánh giá vi phạm → thông báo phù hợp → cải tiến.

Kết thúc chương: bảo mật là một hệ thống quyết định

01 CIA xác định điều cần bảo vệ

02 Zero Trust kiểm soát cách truy cập

03 DDoS, APT và Social Engineering đòi hỏi phòng thủ khác nhau

04 ISO 27001 tổ chức hóa quản trị rủi ro

05 GDPR gắn bảo mật với quyền và trách nhiệm dữ liệu

Exit ticket: chọn một dịch vụ của trường và đề xuất 01 rủi ro + 01 kiểm soát + 01 chỉ số đo hiệu quả.